VOLUME 1: GRC CASE STUDY

PHASES 1 + 2: Virtualbox Networking and Central SIEM Setup

Private lab network (*CorpNetwork*)

- **Configuration**: I created a VirtualBox NAT Network named *CorpNetwork* with the IPv4 subnet “10.0.5.0/24”, providing usable addresses from “10.0.5.1” to “10.0.5.254”. I left DHCP enabled so client machines could receive addresses automatically. I disabled IPv6 in the NAT network settings and unchecked it on the domain controller’s network adapter.
- **Relevant security controls**: This design relates to the Firewalls control in UK Cyber Essentials, ISO/IEC 27001:2022 Annex A controls 8.20 (networks security) and 8.22 (segregation of networks), and NIST SP 800-53 SC-7 (boundary protection).

Explanation:
I didn't want my lab machines sitting directly on my normal home network, where other devices could discover and scan them. I created a separate NAT network so the virtual machines could communicate with one another without each appearing as a directly addressable device on my home network. I chose “10.0.5.0/24” to give the lab a predictable address range separate from my home network.

Disabling IPv6 was also a security decision. My monitoring was focused on IPv4, so I did not want an unused IPv6 connection on the domain controller that could provide an unmonitored route for traffic or be affected by rogue IPv6 network configuration. Unchecking IPv6 reduced the domain controller’s exposure to IPv6 traffic on that adapter, although it did not disable every IPv6 component in Windows. I treated this as a choice for my lab, not a standard setting for domain controllers. Using a single address scheme also made the lab traffic easier to identify and search in my logs.

My IP Address Management (IPAM) Register

- **Configuration**: Before setting up the virtual machines, I planned fixed addresses for the lab’s main services and left client addresses to DHCP. I recorded the following allocations:
    - “10.0.5.1” - VirtualBox NAT network gateway

    - “10.0.5.10” - Active Directory domain controller and DNS server
    - “10.0.5.20” - Splunk Enterprise server
    - DHCP pool - Client workstations, including the Ubuntu endpoint “CORP-CL-01”, receive their IP addresses automatically.
- **Relevant security control**: This address register supports the asset identification covered by ISO/IEC 27001:2022 Annex A control 5.9 (inventory of information and other associated assets).

Explanation:
I planned the addresses before deploying the machines so I would know where to find each of the lab’s main services. The domain controller and Splunk server had fixed addresses that I could use consistently when configuring DNS, log forwarding and connections between machines. Workstations received addresses through DHCP, which made it easier to add a client without assigning an address by hand. The register gave me a straightforward record of which address belonged to each main system and helped me manage the lab as it grew.

Configuring the Central Logging Server and SSH access

- **Configuration:** I installed Ubuntu Server without a graphical desktop to host Splunk Enterprise. I allocated 4 GB of RAM, two CPU cores and a 40 GB virtual disk using Logical Volume Manager (LVM). I set the virtual network adaptor’s promiscuous mode to Deny. This is to ensure that it simulates a real-world corporate environment where the risk of packet sniffing is brought to a minimum. I also enabled OpenSSH Server and configured a VirtualBox port forwarding rule so I could connect from Command Prompt on my Windows 11 host using “ssh sec-analyst@127.0.0.1 -p 2222”.
- **Relevant security controls:** This configuration relates to the Secure Configuration control in UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.9 (configuration management), and NIST SP 800-53 controls CM-6 (configuration settings) and AC-17 (remote access).

Explanation:
I chose Ubuntu Server without a desktop because I intended to manage Splunk through its web interface and administer the operating system through the command line. Leaving out the graphical desktop reduced the software installed on the server and saved resources on my laptop. I allocated two CPU cores and 4 GB of RAM for the virtual machine, and used LVM so I would have flexibility to extend its storage later if needed.

*Setting promiscuous mode to **Deny** meant this virtual adaptor would not be shown traffic addressed to other machines. For administration, I used SSH: the port forwarding rule connected port 2222 on my Windows host to the server's SSH service. That let me open an encrypted terminal session from Command Prompt without placing the server directly on my home network.*

Managing Access to the Splunk Server

- **Configuration:** VirtualBox NAT did not accept unsolicited inbound connections to the lab machines. I added two port forwarding rules so I could reach specific services on the Splunk server from my Windows 11 host:
    - 127.0.0.1:2222 → 10.0.5.20:22 - SSH access to the server
    - 127.0.0.1:8000 → 10.0.5.20:8000 - access to Splunk Web
- **Relevant security controls:** This arrangement relates to the Firewalls control in UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.20 (networks security), and NIST SP 800-53 controls SC-7 (boundary protection) and AC-17 (remote access).

Explanation:
I wanted to manage the Splunk server from my laptop without making its SSH and web services directly accessible from my home network. I bound both forwarding rules to "127.0.0.1", so I could use the forwarded ports on the Windows host, while other devices on my home network could not reach them through my laptop's network address.

*The SSH rule mapped port 2222 on my laptop to port 22 on the server and gave me an encrypted terminal connection. The Splunk Web rule mapped port 8000 on my laptop to the same port on the server. These rules controlled access **through the Windows host**; they did not change how other machines already connected to CorpNetwork could reach the Splunk server.*

Application Separation & My Non-Root Service Settings

- **Configuration:** I installed Splunk Enterprise in "/opt/splunk" and changed ownership of that directory and its contents to a dedicated "splunk" user and group using "sudo chown -R splunk:splunk /opt/splunk". I then configured the Splunk service to run as the "splunk" user rather than as "root".
- **Relevant security controls:** This approach relates to the User Access Control area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.2 (privileged access rights), and NIST SP 800-53 AC-6 (least privilege).

Explanation:
I did not want the service that processes and stores my security logs to have full administrative access to the Ubuntu server. Changing ownership of "/opt/splunk" allowed the dedicated account to access the files Splunk needed; configuring the service to run as that account meant its processes did not routinely operate as "root".

This limits the privileges available to Splunk during normal operation. If a vulnerability allowed someone to run commands through the Splunk process, those commands would initially have the permissions of the "splunk" account rather than unrestricted root access. That is the reason I separated the application from the server's administrative account.

PHASE 3: WINDOWS ACTIVE DIRECTORY PROVISIONING & IDENTITY CORE HARDENING

Provisioning My Primary Identity Controller (*CORP-DC-01*)

- Configuration: I created a virtual machine for Windows Server 2022 Standard with Desktop Experience, allocating two vCPUs, 3 GB of RAM and a 40 GB thin-provisioned virtual disk. I connected it to the *CorpNetwork* NAT network (10.0.5.0/24). I used the manual installation process so I could choose and review the operating system settings before configuring the server as a domain controller.
- Relevant security controls: This work relates to the Secure Configuration area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.9 (configuration management), and NIST SP 800-53 CM-2 (baseline configuration).

Explanation:
I built a dedicated Windows server to manage accounts and authentication centrally as the lab grew. That would let me apply settings through Active Directory and review security events without managing each machine's accounts independently.

My laptop had 16 GB of RAM and needed to run the domain controller alongside Splunk and the other virtual machines, so I allocated 3 GB to this server. I chose Desktop Experience because I wanted to use the graphical management tools, including Group Policy Management and Event Viewer, while learning and checking the configuration. I also worked through the installation manually so I could see the settings I was choosing rather than accept an unattended setup.

Creating the Active Directory Forest (*apex-corp.local*)

- **Configuration:** Before promoting the Windows server, I renamed it *CORP-DC-01*. I then used Server Manager to install the Active Directory Domain Services (AD DS) and DNS Server roles. I promoted the server to a domain controller and created a new forest named *apex-corp.local*, with *APEX-CORP* as its NetBIOS domain name.
- **Relevant security controls:** This work relates to the Secure Configuration area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 5.16 (identity management), and NIST SP 800-53 IA-4 (identifier management).

Explanation:
I renamed the server before promotion so it would have its intended name when the domain controller and its DNS records were created. The forest gave me a central place to manage the lab's domain accounts, computers and Group Policy. Installing DNS on the domain controller allowed client machines configured to use that server for DNS to find the domain services they needed.

I chose apex-corp.local as the name for this self-contained lab forest. The domain name identified my Active Directory environment; the network separation and DNS settings described in the surrounding sections determined how the machines connected and where they sent their lookups.

Configuring the Domain Controller's IP Address and DNS

- **Configuration:** I changed the primary network adaptor (*Ethernet0*) from DHCP to a static IPv4 configuration:
    - Static IPv4 Address: *10.0.5.10*
    - Subnet Mask: *255.255.255.0*
    - Gateway Router: *10.0.5.1*
    - DNS setting during promotion: 127.0.0.1 (the server itself, via loopback)
    - DNS setting after promotion: 10.0.5.10 (the server's network address)
- **Relevant security controls:** This documented configuration relates to the Secure Configuration area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.9 (configuration management), and NIST SP 800-53 CM-6 (configuration settings).

Explanation:
I gave the domain controller a fixed address because the other machines needed a reliable address for the DNS server that holds the lab's Active Directory records. If that

address changed unexpectedly, clients still using the old DNS address could have difficulty finding the domain controller.

During promotion, I set the server's DNS client to "127.0.0.1", which refers back to its own DNS service. This directed the server's DNS queries to its own DNS service while I set up the domain. After promotion, I changed that setting to "10.0.5.10", the address assigned to its network adaptor. Both settings directed the server's own DNS queries to itself. Other machines on CorpNetwork could be configured to use "10.0.5.10" as their DNS server so they could locate the domain controller and its services.

Reducing the Domain Controller's IPv6 Attack Surface

- **Configuration:** I unchecked IPv6 in the properties of the domain controller's primary network adaptor (*Ethernet0*). After changing the network settings, I cleared the DNS client cache and checked resolution of the lab domain:

    - ipconfig /flushdns
    - nslookup apex-corp.local

The lookup returned "10.0.5.10", the domain controller's IPv4 address.

- **Relevant security controls:** This lab configuration relates to the Secure Configuration area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.9 (configuration management), and NIST SP 800-53 CM-7 (least functionality).

Explanation:
I made this change while trying to resolve a domain connectivity problem. The domain controller had a fixed IPv4 address of "10.0.5.10", and I wanted to test name resolution using that address without an unused IPv6 path on its network adaptor complicating the investigation.

I also had a security reason for the choice. My lab addressing and monitoring were focused on IPv4, so removing IPv6 from Ethernet0 reduced the domain controller's exposure to IPv6-specific traffic and rogue network configuration that I was not monitoring. After the change, I cleared the DNS client cache with "ipconfig /flushdns" and ran "nslookup apex-corp.local". The result showed that the domain name resolved to "10.0.5.10". That confirmed the DNS answer I needed for the IPv4 setup, though the lookup alone did not identify the original cause of the connection problem.

PHASE 4: DEPLOYING THE LINUX CLIENT WORKSTATION (*CORP-CL-01*)

Choosing and Configuring the Ubuntu Client

- **Configuration:** I installed Ubuntu Desktop 24.04 LTS (64-bit) on *CORP-CL-01* and connected it to the private *CorpNetwork* NAT network. The workstation received its IP address through DHCP. I used a 25 GB thin-provisioned virtual disk and, after the initial installation, set the VM to one vCPU and 2 GB of RAM.
- **Relevant security controls: The documented VM configuration relates to the Secure Configuration area of UK Cyber Essentials, ISO/IEC 27001:2022 Annex A control 8.9 (configuration management), and NIST SP 800-53 CM-2 (baseline configuration).**

Explanation:
I added an Ubuntu workstation alongside the Windows domain controller so the lab included both Linux and Windows systems. That gave me two different sources of security events to collect and compare in Splunk later in the project.

My laptop had 16 GB of RAM, so I kept the workstation's allocation to one vCPU and 2 GB while running it alongside the domain controller and Splunk server. I used DHCP for the client because it did not need the fixed address I had assigned to the lab's main servers.

Workstation Identity and Sign-in settings

- **Configuration:** I installed Ubuntu Desktop with a clean partition layout, changed the workstation's hostname to *CORP-CL-01*, and created a local account named *corp-user*. I disabled automatic sign-in so that the account password was required to open a desktop session.
- **Relevant security controls:** UK Cyber Essentials User Access Control; ISO/IEC 27001:2022 Annex A.8.5 (Secure authentication); NIST SP 800-53 Rev. 5 IA-2 (Identification and Authentication (Organizational Users)).

Explanation:
I wanted the workstation to have a clear identity within the lab and to require a password before anyone could use its desktop. The CORP-CL-01 hostname made it recognisable on the network, while corp-user gave me a named local account for everyday activity and the authentication events I would examine later. I initially

overlooked that this account also belonged to the sudo group. I discovered that during my later access review and removed the membership in Phase 7.

PHASE 5: CENTRALISING THE TELEMETRY PIPELINE AND RESOLVING STORAGE ISSUES (PART 1)

Transferring the Splunk Universal Forwarder installer

- **Configuration:** I downloaded the Splunk Universal Forwarder installer to my Windows 11 host after a direct download on *CORP-DC-01* failed and an SMB transfer was unavailable. I used “scp -P 2222” to copy the installer through my existing localhost port forward into *sec-analyst*’s directory on the Linux Splunk server (10.0.5.20). I then opened an administrative shell on *CORP-DC-01* and used SCP to pull the file from “sec-analyst@10.0.5.20” onto the Windows desktop.
- **Relevant security controls:** UK Cyber Essentials Firewalls; ISO/IEC 27001:2022 Annex A.8.24 (Use of cryptography); NIST SP 800-53 Rev. 5 SC-8 (Transmission Confidentiality and Integrity).

Explanation:
I hit a roadblock when a direct download onto my domain controller failed and an SMB transfer was unavailable. I copied the installer from my laptop to the Splunk server using the SSH port forward I had already configured. From the domain controller, I then used SCP to pull the file from the Splunk server. This let me install the forwarder without changing my network access rules, while SCP encrypted both file transfers.

Telemetry Ingestion Design & Credential Hardening

- **Configuration:** I installed the Splunk Universal Forwarder on *CORP-DC-01* and selected the Windows Security, Application and System event logs for collection. I directed the forwarder to the Splunk server at “10.0.5.20:9997”. During the MSI installation, I also created a username and password for the forwarder’s Splunk administrator account, which I would use to manage its configuration.
- **Relevant Security Controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and A.8.5 (Secure authentication); NIST SP 800-53 Rev. 5 AU-2 (Event Logging) and IA-2 (Identification and Authentication (Organizational Users)).

Verification Search (SPL):

index=main host=CORP-DC-01

Explanation:
I configured the domain controller to send its event logs to Splunk so I could investigate activity from a separate machine. The Security log was particularly useful for examining authentication events, while the Application and System logs provided context about software and operating system activity. Once Splunk had received an event, clearing the corresponding log on the domain controller would not erase that indexed copy.

I also set credentials for the forwarder's own administrator account when the installer prompted me. That meant managing the agent through Splunk's authenticated interface required a login. I wanted access to its configuration controlled because changing or stopping a forwarder could interrupt the flow of evidence into the SIEM.

PHASE 5: CENTRALISING THE TELEMETRY PIPELINE AND RESOLVING STORAGE ISSUES (PART 2)

Responding to Splunk's low disk space threshold

- **Configuration:** Splunk's DiskMon safeguard stopped indexing when free space on the SIEM server fell below its default threshold of approximately 5,000 MB. Searching was also affected. I added a "[diskUsage]" section to "/opt/splunk/etc/system/local/server.conf" and set "minFreeSpace = 500", lowering the threshold to 500 MB.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.6 (Capacity management) and A.8.9 (Configuration management); NIST SP 800-53 Rev. 5 CM-6 (Configuration Settings).

Explanation:
I encountered a storage problem just as I was bringing logs into Splunk: its DiskMon safeguard stopped indexing, and searching was also affected. I traced this to the free space on the SIEM server's filesystem falling below Splunk's default 5 GB minimum. Rather than expand the virtual disk and LVM allocation immediately, I made a temporary change in "/opt/splunk/etc/system/local/server.conf", lowering the threshold to 500 MB so I could resume the logging work.

I knew this restored operation by reducing the safety buffer, not by creating more space. I recorded the reason for the change and planned to expand the virtual disk to 100 GB and extend LVM. Once the filesystem had sufficient capacity, I could remove the override and return to the default 5 GB threshold; doing so before the expansion would stop indexing again.

Running the Splunk VM headlessly

- **Configuration:** I started the VirtualBox VM named *Corp-Splunk-Server* without opening its graphical console, using “VBoxManage startvm "Corp-Splunk-Server" --type headless**.”**
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.6 (Capacity management).

Explanation:
My 16 GB laptop had to run the Splunk server alongside the domain controller and Ubuntu client. Once the server was set up, I no longer needed to keep its VirtualBox console open, so I launched the VM in headless mode. This avoided the host-side graphical window while the server continued running with its existing resource allocation. I managed Ubuntu through the SSH connection I had already configured on “127.0.0.1:2222”.

Staging the Linux Universal Forwarder

- **Configuration:** I installed the Splunk Universal Forwarder Debian package on CORP-CL-01 under “/opt/splunkforwarder”. My initial attempt to download the package directly on the client with “wget” returned HTTP 403 Forbidden. I staged the package on the Linux Splunk server and transferred it to the client using SCP over the internal network on port 22.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.24 (Use of cryptography); NIST SP 800-53 Rev. 5 SC-8 (Transmission Confidentiality and Integrity).

Explanation:
I ran into a practical obstacle while installing the Linux forwarder: the download request from CORP-CL-01 was refused with an HTTP 403 response. That told me the download had failed, although it did not establish why the server refused it. I obtained the package on my Splunk server instead, copied it across CorpNetwork with SCP, and installed it on the client. This let me continue the deployment without changing the lab’s network rules, while SCP protected the file during the transfer.

Target Authentication Telemetry Hooks

- **Configuration:** I configured the Splunk Universal Forwarder on “CORP-CL-01” to monitor “/var/log/auth.log” and send the collected events to the Splunk server at “10.0.5.20:9997”.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and NIST SP 800-53 Rev. 5 AU-2 (Event Logging).

Explanation:
I wanted the Linux workstation’s authentication activity to be visible alongside the logs from my Windows domain controller. I selected “`/var/log/auth.log`” because it records activity such as login attempts and use of “`sudo`”. I then configured the forwarder to send those records to my central Splunk server. Once an event has been received and indexed there, deleting the workstation’s local log would not remove that central copy. This gives me a more useful record for investigating access to the client, while the events I can see still depend on what Ubuntu writes to that file and whether forwarding is working.

Validating Cross-Platform Log Ingestion

- **Configuration:** I configured the forwarders on “CORP-DC-01” (Windows Server) and “CORP-CL-01” (Ubuntu Desktop) to send their selected logs to the Splunk server at “10.0.5.20:9997”.
- **Verification:** I ran “index=main | stats count by host” in Splunk. The results showed event counts for both “CORP-DC-01” and “CORP-CL-01” in the “main” index.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and NIST SP 800-53 Rev. 5 SI-4 (System Monitoring).

Explanation:
The Windows server and Linux workstation produce different kinds of logs, so I needed to check that both were reaching the same place. After configuring their forwarders, I searched the “main” index and grouped the event counts by host. Seeing both machines in the results confirmed that Splunk had received and indexed events attributed to each of them. It gave me one place to begin investigating activity across the two systems. I would still need to inspect the event sources and timestamps separately to check that the specific logs I wanted were arriving consistently.

PHASE 6: ENTERPRISE SECURITY ARCHITECTURE COMPLIANCE AUDIT & POLICY REGISTRY

Reviewing the Domain Controller's IPv6 Setting

- **Configuration review:** I checked the active network adapter on "CORP-DC-01" and confirmed that the IPv6 binding remained unticked. I recorded this alongside the server's static IPv4 address, "10.0.5.10", as part of my lab configuration review.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.9 (Configuration Management) and NIST SP 800-53 Rev. 5 CM-6 (Configuration Settings).

Explanation*:*
During the build, I had difficulty connecting to the domain controller, so I unticked IPv6 on its active network adapter while checking its network and DNS configuration. The choice also fitted my security plan for this IPv4-based lab: I wanted to reduce the opportunity for IPv6 traffic or configuration on that interface to provide an overlooked route into the server. That concern connected with the IPv6-based network attacks I was considering in my threat intelligence work. In this later review, I confirmed that the setting remained in place and recorded both reasons for making the change. My subsequent DNS lookup showed "`apex-corp.local`" resolving to "`10.0.5.10`", although that result alone could not establish whether IPv6 had caused the original connection problem.

Auditing Splunk's Service Account

- **Configuration review:** I checked "corp-splunk-hub" and verified that the Splunk service was running as the dedicated "splunk" account rather than "root". I had assigned ownership of the installation directory to that account with "sudo chown -R splunk:splunk /opt/splunk", allowing the service to access its own files without running with full operating system privileges.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.2 (Privileged Access Rights) and NIST SP 800-53 Rev. 5 AC-6 (Least Privilege).

Explanation:
The Splunk server holds my central security logs, so I wanted to limit the privileges used by its day-to-day processes. A service running as "root" would give an attacker who exploited that process a much more powerful starting position on the Ubuntu server. I assigned the Splunk files to a dedicated service account, ran the service under that account and checked its running identity during this audit. This reduces the operating

system access available through the Splunk process. A compromise could still affect files and data that the splunk account can access, so the account is a privilege boundary, not a guarantee that the SIEM or its records cannot be altered.

Auditing the CorpNetwork Boundary

- **Configuration review:** I reviewed the VirtualBox “CorpNetwork” NAT segment (10.0.5.0/24) and its port-forwarding rules. The virtual machines used private addresses within that segment rather than appearing directly on my home network. The two host access rules were bound to my laptop’s loopback address:
    - “127.0.0.1:2222” → “10.0.5.20:22” for SSH access to the Splunk server.
    - “127.0.0.1:8000” → “10.0.5.20:8000” for the Splunk web interface.
- **Relevant security controls:** UK Cyber Essentials (Firewalls), ISO/IEC 27001:2022 Annex A.8.20 (Networks Security) and A.8.22 (Segregation of Networks).

Explanation:
I built “CorpNetwork” to keep the lab machines separate from devices on my normal home network and to avoid exposing their management services directly through my laptop’s network address. During this review, I checked the NAT arrangement and the two rules I had created to reach the Splunk server. Binding those rules to “127.0.0.1” meant I could open SSH and the Splunk interface from my laptop without making those forwarded ports available through its home-network connection. The virtual machines could communicate with one another inside “CorpNetwork”; that internal traffic did not weaken the boundary with my home network. VirtualBox NAT also provided a route for outbound connections through my host. So the lab could be described as a private NAT segment with restricted inbound management access rather than an air-gapped network.

Reviewing Centralised Log Collection

- **Configuration review:** I reviewed the forwarding configuration for “CORP-DC-01” and “CORP-CL-01”. The Windows forwarder was configured to collect the Security, Application and System event logs; the Linux forwarder monitored “/var/log/auth.log”. Both were configured to send data to the Splunk server at “10.0.5.20:9997”. My earlier search of the “main” index returned events attributed to both hosts.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and NIST SP 800-53 Rev. 5 AU-9 (Protection of Audit Information).

Explanation:
I wanted the lab's security logs to remain available for investigation even if someone altered the local records on a workstation or the domain controller. I configured the two forwarders to send their selected logs to a separate Splunk server, then checked that events from both hosts appeared in the central index. Once an event has been indexed there, clearing the corresponding local log alone would not remove that central copy. This improves the resilience of my audit trail, although it does not make the records immutable: an attacker could still disrupt future forwarding or target the Splunk server itself.

Reviewing the Splunk Disk Space Exception

- **Configuration review:** I reviewed "/opt/splunk/etc/system/local/server.conf" (Splunk's settings) and confirmed that I had lowered the minimum free disk space it requires to 500 MB from 5,000MB.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.6 (Capacity Management) and A.8.9 (Configuration Management); NIST SP 800-53 Rev. 5 CM-6 (Configuration Settings).

Explanation:
I encountered a storage problem when free space on the Splunk server fell below its default 5 GB safety threshold, interrupting indexing and searching. After identifying the DiskMon setting responsible, I added a local configuration override that reduced the threshold to 500 MB and allowed the lab's log collection and searches to resume. I recorded this as a temporary lab risk exception because the change gave Splunk less room to absorb further log growth; it did not increase the disk's capacity. My planned remedy is to expand the virtual disk and its LVM storage to 100 GB, then review and remove the override once there is enough free space for the default threshold.

Simulated Information Security Policy: Lab Infrastructure

- ***Document reference:*** *APEX-ISP-2026-V1 (lab exercise)*
- ***Scope:*** *“CORP-DC-01”, “CORP-CL-01”, “corp-splunk-hub” and the “CorpNetwork” segment within the simulated “apex-corp.local” environment.*

Control 2.1: Network Protocol Configuration

- ***Policy requirement:*** *Network protocols on identity servers must be reviewed against the lab’s operating needs and the software vendor’s guidance. A decision to disable a protocol must have a recorded reason, an assessment of its effect on connectivity and a way to check the resulting configuration.*
- ***Lab application:*** *On “CORP-DC-01”, I unticked IPv6 on the active network adapter while troubleshooting domain connectivity and to reduce IPv6 exposure on that interface in my IPv4-based lab. I recorded this as a decision specific to that server.*
- ***Review method:*** *Check the adapter configuration and relevant DNS and connectivity results after the change. Revisit the decision if the network design changes.*

Explanation:
I used this control to practise turning a technical choice into a decision that another administrator could understand and review. My change on “CORP-DC-01” had two reasons: I was troubleshooting a connection problem, and I wanted to reduce an IPv6 route I was not using in the lab. Recording the reasons, scope and checks means a future domain controller would receive its own assessment rather than automatically inheriting the same setting.

Control 2.2: Least Privilege for the Splunk Service

- ***Policy requirement:*** *The Splunk service on “corp-splunk-hub” should run under a dedicated account with the permissions it needs for its work, rather than running as “root”. Ownership of the installation files should allow that account to operate the service without granting it wider administrative privileges.*
- ***Lab application:*** *I assigned “/opt/splunk” to the “splunk:splunk” account and configured the Splunk service to run as “splunk”.*
- ***Review method:*** *Check the account running the Splunk process and the ownership of “/opt/splunk”. If either differs from the documented configuration, investigate the reason and correct it without unnecessarily interrupting log collection.*

Explanation:

I wanted the account running Splunk to have enough access to operate the service without giving it control over the whole Ubuntu server. If the service ran as "root", an attacker who exploited it could gain much broader operating system access. The dedicated "splunk" account limits that access. It still needs to work with Splunk's files and indexed data, so this control reduces the potential impact of a compromise without making those records untouchable.

Control 2.3: Centralised Security Logging

- ***Policy requirement:*** *The domain controller and client workstation should send their selected security logs to the separate Splunk server. Local logs should remain available, but they should not be the only copy used for investigation.*
- ***Lab application:*** *I configured the Universal Forwarder on "CORP-DC-01" to collect the Windows Security, Application and System event logs, and the forwarder on "CORP-CL-01" to monitor "/var/log/auth.log". Both were configured to send data to "10.0.5.20:9997".*
- ***Review method:*** *Check each forwarder's configured inputs and destination, then search Splunk for recent events from the intended log sources on both hosts. If expected events stop arriving, investigate the forwarder, its access to the logs, the network connection and available storage.*

Explanation:

I wanted a separate copy of selected security events because someone with sufficient access to an endpoint may be able to clear its local logs. Forwarding those events to Splunk gives me another place to investigate them once they have been indexed. My earlier search showed events attributed to both machines; checking the individual sources and recent timestamps would give me a fuller picture of whether the intended feeds were still working.

Control 2.4: Access to the Lab Network and Management Services

- ***Policy requirement:*** *Virtual machines in "CorpNetwork" should use the private NAT segment. Any port-forwarding rule created for administration should have a documented purpose and be bound to the host laptop's loopback address, unless a wider connection is specifically needed and reviewed.*
- ***Lab application:*** *I placed the lab machines on "CorpNetwork" (10.0.5.0/24). I configured "127.0.0.1:2222" to forward to the Splunk server's SSH port at*

“10.0.5.20:22”, and “127.0.0.1:8000” to forward to its web interface at “10.0.5.20:8000”.

- ***Review method:*** *Check the VirtualBox network settings and port-forwarding rules to confirm that each rule still serves a purpose and that its host address remains “`127.0.0.1`”. Remove rules that are no longer needed.*

Explanation:
I wanted the lab machines to communicate with one another while keeping their addresses separate from devices on my home network. I also needed to manage the Splunk server from my laptop, so I created two specific port forwards bound to its loopback address. Reviewing those rules matters because changing a host address or leaving an unnecessary forward in place could expose a management service more widely than I intended.
